FICHE 25 - API : INTERFACES DE PROGRAMMATION APPLICATIVE

Veiller à sécuriser des données partagées via l'implémentation d'une API.

Le recours à des interfaces de programmation applicative (API en anglais) constitue une bonne pratique pour de nombreux cas d'usages d'échange de données personnelles, dans la mesure où les API peuvent contribuer à fiabiliser, minimiser et sécuriser ces échanges. La gestion des API doit, pour ce faire, s'inscrire dans la politique de sécurité des systèmes d'information et faire l'objet d'une coordination entre fournisseurs et consommateurs d'API.

Les précautions élémentaires

- Identifier les acteurs et leur **rôle fonctionnel** (détenteur de données, gestionnaire d'API, réutilisateur[130]) afin d'organiser le périmètre d'attribution de chacun en matière **d'accès aux API et aux données**.
- Limiter le partage aux **données strictement nécessaires**, uniquement aux **personnes et pour les finalités prévues**, en application du principe de minimisation.
- Créer une séparation entre les appels aux fonctions courantes de l'API et ceux dédiés à son administration, pour lesquels une authentification robuste apparaît nécessaire.
- Disposer de **journaux pertinents** afin de tracer les échanges (voir la fiche n°16 - Tracer les opérations) et de détecter et réagir en cas d'une utilisation détournée de l'API, d'accès illégitime aux données, d'un dépassement de la capacité d'accès ou de tout autre comportement inhabituel (voir la fiche n°19 - Gérer les incidents et les violations).
- **Maintenir à jour la documentation**. Celle-ci doit inclure le **format des requêtes et des données** concernées par le partage afin de limiter le risque d'une erreur d'interprétation.

Ce qu'il ne faut pas faire

- Conserver **actives les anciennes versions d'une API** qui ne permettent pas le maintien du niveau de sécurité attendu.
- Négliger la sécurité des **clés d'accès aux API**, alors que des solutions de sécurisation des secrets, tel qu'un coffre-fort numérique, existent.

130 Le réutilisateur de données est tout organisme envisageant d'accéder ou recevant des données par voie d'API en vue de les exploiter pour son propre compte.